

CYMAG AutoScanner

Relatório de Diagnóstico de Segurança

Alvo	10.10.100.0/24
Data/Hora	09/06/2026 02:10:18
Total de Achados	13
CRÍTICO	8
ALTO	1
MÉDIO	2
BAIXO	2

Achados de Segurança

[CRÍTICO] SQL Injection Detectado CVSS 9.8	
Host	10.10.100.100:80 — HTTP
Descrição	Endpoint retorna erros SQL ao receber entrada malformada. Pode permitir extração completa do banco de dados.
Evidência	GET /api/collaborators?name=' → erro SQL na resposta

[CRÍTICO] Broken Authentication — Token Base64 Forjável CVSS 9.1	
Host	10.10.100.100:80 — HTTP
Descrição	O token de sessão é simplesmente Base64 de usuario:role:contexto sem assinatura criptográfica. Qualquer usuário pode forjar um token de administrador sem conhecer a senha.
Evidência	Token forjado aceito em /admin (HTTP 200)

[CRÍTICO] Node-RED Sem Autenticação CVSS 9.8	
Host	10.10.100.100:1880 — Node-RED
Descrição	A interface administrativa do Node-RED v4.1.10 está acessível sem credenciais. Qualquer usuário na rede pode visualizar e modificar fluxos de automação industrial (OT).
Evidência	GET /settings → 200 versão 4.1.10 funcExtModules: True

[CRÍTICO] RCE Potencial — functionExternalModules Ativo CVSS 9.1	
Host	10.10.100.100:1880 — Node-RED
Descrição	A flag functionExternalModules:true permite que funções JS carreguem child_process e executem comandos no SO do servidor.

Evidência	"functionExternalModules": true
-----------	---------------------------------

[CRÍTICO]	Código-Fonte de Automação Industrial Exposto	CVSS 8.6
Host	10.10.100.100:1880 — Node-RED	
Descrição	37 nós de automação acessíveis sem autenticação. Expõe lógica de negócio, tópicos MQTT e possíveis credenciais.	
Evidência	GET /flows → 200 37 nós	

[CRÍTICO]	Sistema SCADA/OT de Bombas de Combustível Exposto	CVSS 9.5
Host	10.10.100.100:1880 — Node-RED	
Descrição	Flows expõem sistema de monitoramento e controle de bombas industriais via MQTT. Atacante pode injetar telemetria falsa e manipular ordens de reabastecimento.	
Evidência	Tópicos: fuel-pumps/data, fuel-pumps/refill-request	

[CRÍTICO]	Broker MQTT Sem Autenticação e Sem TLS	CVSS 9.3
Host	10.10.100.100:1883 — MQTT	
Descrição	O broker MQTT aceita conexões anônimas e transmite dados em texto claro. Qualquer dispositivo pode publicar ou assinar qualquer tópico, incluindo comandos de controle industrial.	
Evidência	Conexão anônima aceita na porta 1883/tcp (sem TLS)	

[CRÍTICO]	MySQL 5.5.62 — Versão EOL (sem patches desde 2018)	CVSS 9.8
Host	10.10.100.100:3307 — MySQL	
Descrição	MySQL 5.5.62 atingiu End-of-Life em 2018 e não recebe mais correções de segurança. Múltiplas CVEs críticas sem patch disponível.	
Evidência	Versão: MySQL 5.5.62 (EOL desde 2018)	

[ALTO]	Endpoint Sensível Exposto: /api/collaborators	CVSS 7.5
Host	10.10.100.100:80 — HTTP	
Descrição	Endpoint colaboradores acessível sem autenticação adequada.	
Evidência	GET /api/collaborators → HTTP 200	

[MÉDIO]	Headers de Segurança Ausentes	CVSS 5.3
Host	10.10.100.100:80 — HTTP	
Descrição	A aplicação não implementa headers de segurança HTTP recomendados, deixando usuários expostos a ataques como clickjacking e XSS.	
Evidência	Ausentes: X-Content-Type-Options, X-Frame-Options, Content-Security-Policy, Strict-Transport-Security	

[MÉDIO]	Endpoint Sensível Exposto: /admin	CVSS 5.0
Host	10.10.100.100:80 — HTTP	

Descrição	Painel admin acessível sem autenticação adequada.
Evidência	GET /admin → HTTP 401

[BAIXO]	Divulgação de Versão do Servidor Web	CVSS 3.1
Host	10.10.100.100:80 — HTTP	
Descrição	O header Server revela versão exata, facilitando ataques direcionados.	
Evidência	Server: nginx/1.24.0	

[BAIXO]	MySQL em Porta Não Padrão (3307)	CVSS 2.0
Host	10.10.100.100:3307 — MySQL	
Descrição	Uso de porta não padrão pode indicar tentativa de ofuscação. Não é uma medida de segurança efetiva.	
Evidência	MySQL respondendo em 3307/tcp	

AVISO LEGAL: Este relatório foi gerado automaticamente pela ferramenta CYMAG AutoScanner e pela IA Groq (Llama). Os resultados podem conter imprecisões ou falsos positivos. Recomenda-se revisão por profissional especializado em segurança cibernética antes de qualquer decisão.